

Password Attacks

Unit 14 — Module 3: Exploitation (final unit)

Passwords are still the front door to most systems — and most break-ins. We'll learn how they're stored, how attackers attack them, and how to **defend** them.

Learning Objectives

By the end of this unit you can:

- **Explain** how passwords are stored: plaintext (bad), **hashing**, **salting**.
- **Identify** common hash types (**MD5/SHA** weak, **bcrypt** strong) and why.
- **Distinguish online** attacks (live login) from **offline** attacks (stolen hashes).
- **Compare** brute force vs. **dictionary/wordlist** attacks (e.g., **rockyou**).
- **Use Hydra** against a **lab** login service.
- **Use John the Ripper** (and/or **Hashcat**) to crack **sample** hashes.
- **Describe password spraying** and why it dodges lockouts.
- **Recommend** defenses: long unique passwords, **MFA**, **lockout**, strong hashing.

How passwords are stored

Way	What's stored	Verdict
Plaintext	the actual password	 disaster if leaked
Hash	a one-way scramble	 can't be reversed
Hash + salt	scramble + random per-user data	  best

- A **hash** is one-way: same input → same hash, but you **can't reverse** it.
- You can only **guess** a word, hash it, and compare.

Hashing and salting in action

```
echo -n "password1" | md5sum      # always the same hash
echo -n "password1" | md5sum      # identical to above
echo -n "Password1" | md5sum      # ONE change -> totally different
```

- Same input always gives the same hash (deterministic).
- One character change → a completely different hash (the **avalanche effect**).
- A **salt** = random data added per password, so two users who both pick `password1` get **different** hashes — defeating reuse-spotting and rainbow tables.

Weak vs. strong hashes

Algorithm	Speed	Good for passwords?
MD5 / SHA	very fast	 fast = easy to crack
bcrypt	slow + salted	 designed to resist cracking

Fast hashing helps the attacker (millions of guesses/sec). **Slow, salted** hashing is the goal — every guess costs the attacker real time.

Online vs. offline attacks

	Online	Offline
Target	a live login service	captured hash file
Noise	loud, can trigger lockouts	silent — no contact with target
Speed	slow	as fast as your hardware
Tool	Hydra	John, Hashcat

Online = you're knocking on the real door. Offline = you stole the lockbox and crack it at home.

Brute force vs. wordlists

- **Brute force** — try *every* combination. Thorough, but very slow.
- **Dictionary / wordlist** — try a list of **likely** passwords. Much faster.

```
wc -l /usr/share/wordlists/rockyou.txt    # ~14 million lines  
head /usr/share/wordlists/rockyou.txt    # 123456, password, iloveyou ...
```

rockyou.txt is real passwords from a real breach. Wordlists win because people reuse predictable passwords.

Password spraying

- Brute force = **many** passwords against **one** account → triggers logout fast.
- **Spraying** = **one** common password against **many** accounts.

Each account only sees *one* failed attempt — so simple lockouts don't notice.
That's why spraying is sneaky.

Defense preview: unique passwords + MFA + monitoring for "one password, many accounts."

Online attack with Hydra (lab login ONLY)

```
# SSH
```

```
hydra -l <lab-user> -P /usr/share/wordlists/rockyou.txt ssh://<target-IP>
```

```
# FTP
```

```
hydra -l <lab-user> -P /usr/share/wordlists/rockyou.txt ftp://<target-IP>
```

Success line:

```
[22][ssh] host: <ip> login: <user> password: <found>
```

9

Offline cracking with John the Ripper

```
nano hashes.txt          # paste the sample hashes (one per line)

john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
john --show --format=raw-md5 hashes.txt          # see what cracked
```

- Match `--format` to the hash type (`raw-md5`, `raw-sha1`, `bcrypt`).
- **MD5/SHA** samples fall almost instantly; **bcrypt** is slow or won't crack in class.

```
hashcat -m 0 -a 0 hashes.txt /usr/share/wordlists/rockyou.txt # optional: GPU spe
```

Sample hashes are made from harmless words — **never** real users' passwords.



Defenses: map each attack to its fix

Attack	Defense	Why it works
Hydra online guessing	lockout / rate-limit + MFA	blocks/slows guesses; stolen pw isn't enough
rockyou wordlist	long unique passphrases	not in the list, too long to brute force
John offline (MD5/SHA)	bcrypt (slow, salted)	each guess costs huge time
password spraying	unique passwords + MFA + monitoring	one pw can't open many doors

11

Ethics & Authorization

This is one of the easiest skills to misuse, so the line is **bright**: attack **lab accounts on lab systems** and **authorized rooms** only.

Never a real account, a classmate's account, a school login, or any service you don't own or have written permission to test.

Even **one** unauthorized login attempt can be a crime under the **CFAA**.

The "it's their own account" trap

A friend forgot their email password and asks you to "just crack it — it's their own account."

Even well-meaning, this crosses the line: you don't have authorization, and it's not your account.

The right answer: account **recovery**, not cracking.

We study these attacks to **defend** people — push for MFA, lockouts, strong hashing, and long unique passwords.

Key vocabulary

Term	Meaning
Plaintext	password stored as readable text — a disaster
Hash / Hashing	one-way scramble; can't be reversed
Salt	random per-password data so identical passwords differ
MD5 / SHA / bcrypt	fast (weak) / fast (weak) / slow + salted (strong)
Online / Offline	attack a live login / crack captured hashes
Brute force / Wordlist	every combo / likely passwords (rockyou)
Hydra / John / Hashcat	online tool / offline crackers
Spraying / MFA / Lockout	one pw many accounts / 2nd factor / block after fails



Lab launch

Platform: **Hydra** + **John** (+ optional **Hashcat**) on **Kali**, against an authorized **TryHackMe** room or an isolated **lab login service**.

Your mission:

1. See hashing & salting in action.
2. Inspect **rockyou.txt**.
3. **Hydra** vs. the lab login → recover a credential.
4. **John** vs. sample hashes → watch MD5 fall and bcrypt resist.
5. Build the **attack → defense** table and write the reflection.

Confirm the lab is **isolated** first. Every Hydra target is a lab/authorized target.

15

Recap

- Plaintext is a disaster; **hashing** is one-way; **salting** makes identical passwords differ.
- **MD5/SHA** crack fast; **bcrypt** resists by design.
- **Online** (Hydra, noisy) vs. **offline** (John/Hashcat, silent).
- **Wordlists** beat brute force because people are predictable.
- **Spraying** dodges simple lockouts.
- Defenses: **long unique passwords, MFA, lockout/rate-limiting, strong salted hashing.**

Exit ticket & discussion

Exit ticket: "The single best password defense for most people is ____ because ____."

Discussion: Why did the **bcrypt** sample resist cracking when the **MD5** one fell fast?
And: where exactly is the authorization boundary when someone asks you to crack "their own" account?